

**DOKUMEN EVALUASI PRAKTIKAL (PRACTICAL ASSESSMENT) PROGRAM:
JUNIOR CYBERSECURITY ETHICAL HACKER INTERNSHIP**

Topik: Social Engineering Awareness dan Analisis Kerentanan Session Hijacking Target

Sistem: Portal Finansial PT Teknologi Aman Sejahtera (Sistem Simulasi) Tautan Lab:

<https://website-cybersecurity-testing-lab--bagussudung1602.replit.app>

PENYELENGGARA: PT VINIX SEVEN AURUM

Kelompok 8 :

- Afnan Yazid Pradana
- Kelvin Febrianto
- Kurniawan Saputra
- Rishfan Mailizar

BAB I

RINGKASAN EKSEKUTIF DAN TUJUAN EVALUASI

1.1 Ringkasan Eksekutif

Evaluasi praktikal ini dilaksanakan oleh peserta program *Junior Cybersecurity Ethical Hacker Internship* yang diselenggarakan oleh PT Vinix Seven AURUM. Fokus utama penugasan ini adalah melakukan pengujian keamanan komprehensif terhadap portal finansial internal PT Teknologi Aman Sejahtera (menggunakan sistem simulasi lab). Pengujian ini dirancang untuk mengukur tingkat ketahanan organisasi dari dua sudut pandang utama, yaitu *human layer* (kesadaran pegawai terhadap manipulasi psikologis) dan *technical layer* (kelemahan arsitektur manajemen sesi serta kemampuan pemantauan *log server*).

Berdasarkan hasil pengujian yang dilakukan secara legal dan etis, ditemukan beberapa celah penting yang memerlukan perhatian khusus dari manajemen, di antaranya kerentanan halaman *phishing* simulasi yang memanfaatkan teknik *urgency*, celah keamanan *cookie* yang rentan terhadap eksploitasi *XSS* apabila atribut (HttpOnly) tidak diaktifkan, serta adanya anomali pada log akses server yang mengindikasikan upaya *session hijacking* melalui pergeseran alamat IP dan ketidakcocokan *User-Agent*. Laporan ini menyajikan temuan lengkap beserta rekomendasi teknis dan kebijakan tata kelola untuk memitigasi risiko keamanan di masa mendatang.

1.2 Tujuan Evaluasi

Tujuan dari pelaksanaan evaluasi praktikal ini antara lain:

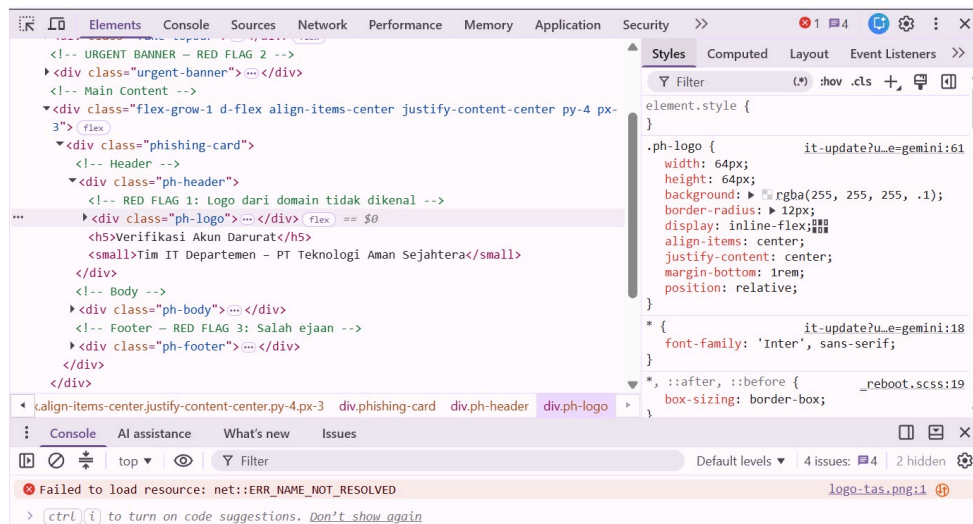
1. Menganalisis Kerentanan *Social Engineering*: Mengidentifikasi indikator mencurigakan (*red flags*) pada halaman web tiruan dan mengevaluasi efektivitas kampanye kesadaran keamanan (*security awareness*) perusahaan.
2. Menguji Ketahanan Manajemen Sesi (*Session Management*): Memeriksa siklus hidup sesi, menganalisis dampak eksposur token melalui skrip *client-side* (JavaScript), serta menguji teknik pembajakan sesi (*session hijacking*) dan mitigasinya menggunakan atribut HttpOnly.

3. Melakukan Forensik Log Server: Berperan sebagai tim *Security Operations Center* (SOC) untuk mendeteksi anomali akses seperti *IP address shift* dan *User-Agent mismatch* yang menandakan adanya penyalahgunaan sesi.
4. Menyusun Rekomendasi Strategis: Memberikan usulan perbaikan teknis aplikasi web serta merumuskan kebijakan Standar Operasional Prosedur (SOP) bagi SDM guna meningkatkan postur keamanan informasi PT Teknologi Aman Sejahtera secara keseluruhan.

BAB II

HASIL PENGUJIAN DAN BUKTI SCREENSHOT

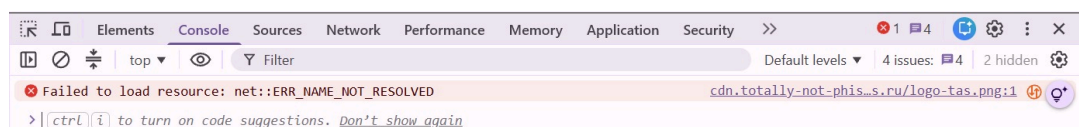
2.1 Bagian 1: Analisis Simulasi Phishing dan Security Awareness



Pada bagian ini, dilakukan evaluasi dan analisis terhadap halaman pembaruan darurat internal (/it-update) yang dirancang sebagai bagian dari simulasi phishing korporat PT Teknologi Aman Sejahtera. Berdasarkan inspeksi dan pengujian yang dilakukan, berikut adalah hasil analisis lengkap beserta bukti pengujian:

A. Identifikasi Red Flags pada Halaman Phishing

1. Red Flag #1 — URL Logo dari Domain Mencurigakan



a. Temuan dan Analisis

Logo perusahaan yang ditampilkan pada halaman pembaruan tidak diambil dari server resmi perusahaan. Berdasarkan inspeksi elemen (Inspect Element) pada peramban, gambar logo dimuat dari domain asing yang tidak dikenal (cdn.totally-not-phishing-assets.ru).

Teknik ini umum digunakan oleh pelaku phishing untuk menghemat bandwidth server serangan mereka serta menghindari deteksi firewall domain internal.

b. Bukti Kode dan URL Perbandingan

- **Mencurigakan:**

```
src="[https://cdn.totally-not-phishing-assets.ru/logo-tas.png](https://cdn.totally-not-phishing-assets.ru/logo-tas.png)"
```

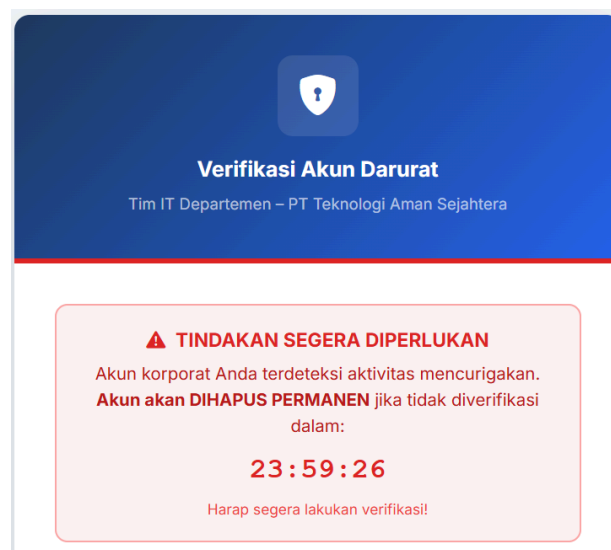
- **Resmi:**

```
src="[https://tas-corp.id/assets/images/logo-official.png](https://tas-corp.id/assets/images/logo-official.png)"
```

c. Prosedur Deteksi

Pengguna dapat memverifikasi keaslian logo dengan klik kanan pada gambar logo → pilih Inspect / Inspect Element → perhatikan atribut src pada tag . Jika domain mengarah ke luar server resmi, halaman tersebut dipastikan merupakan indikasi *phishing*.

2. Red Flag #2 — Urgensi Mengancam & Countdown Timer (Pretexting & Urgency Attack)



a. Temuan dan analisis

Halaman simulasi menggunakan teknik manipulasi psikologis (*Social Engineering*) bertipe Pretexting (membuat skenario palsu sebagai tim IT) serta

memunculkan rasa mendesak yang ekstrem (Scarcity & Urgency Attack). Halaman menampilkan pesan ancaman penghapusan akun beserta penghitung waktu mundur (*countdown timer*) yang berkedip. Tujuan dari manipulasi ini adalah memicu rasa panik (fear & urgency) pada pengguna sehingga mereka terdorong untuk langsung bertindak memasukkan kredensial tanpa sempat memeriksa keabsahan halaman.

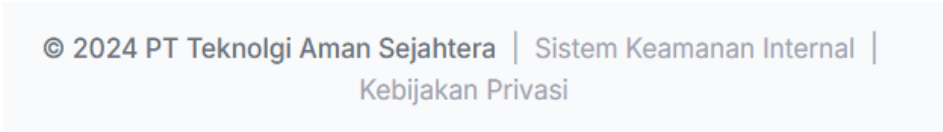
b. Pesan manipulatif yang ditemukan

Pada halaman tersebut terdapat pesan “Akun Anda akan DIHAPUS PERMANEN dalam 24 jam jika tidak diverifikasi!”

c. Prinsip Keamanan (Golden Rule)

Tim IT internal TIDAK PERNAH meminta verifikasi kata sandi melalui halaman web terbatas waktu dengan ancaman penghapusan akun secara mendadak. Jika menerima pesan serupa, pegawai wajib memverifikasi langsung melalui jalur resmi (seperti telepon *Helpdesk* resmi internal).

3. Red Flag #3 — Salah Ejaan Nama Perusahaan di Footer (Typosquatting / Typo Error)



© 2024 PT Teknolgi Aman Sejahtera | Sistem Keamanan Internal |
Kebijakan Privasi

a. Temuan dan Analisis

Pada bagian bawah (*footer*) halaman *phishing*, ditemukan kesalahan penulisan (*typo*) nama entitas korporat. Nama perusahaan tertulis "PT Teknolgi Aman Sejahtera" di mana huruf 'o' pada kata "*Teknologi*" dihilangkan. Dalam skenario dunia nyata, teknik kemiripan ejaan ini berkaitan erat dengan Typosquatting (pendaftaran nama domain yang mirip dengan milik korban untuk menipu pengguna yang kurang teliti).

b. Perbandingan Ejaan

- **Ejaan Palsu:** "PT Teknolgi Aman Sejahtera" (karakter 'o' hilang)
- **Ejaan Resmi:** "PT Teknologi Aman Sejahtera"

c. Mitigasi dan Kebiasaan Buruk

Pegawai dibiasakan untuk selalu meneliti detail teks pada *footer*, termasuk hak cipta (*copyright*), tata bahasa, dan tautan Kebijakan Privasi. Kesalahan ejaan sekecil apa pun pada halaman login/pembaruan merupakan sinyal kuat adanya indikasi penipuan.

B. Analisis Uji Coba Pengiriman Data Formulir dan Dashboard *Campaign*

Setelah melakukan simulasi pengisian formulir dengan data sembarang dan pengalihan ke portal edukasi (/awareness-education), diperoleh beberapa temuan penting terkait privasi serta metrik evaluasi:

1. Uji Coba Formulir & Kebijakan Penyimpanan Kata Sandi (Soal 3a)

a. Analisis Kebijakan Tanpa Penyimpanan Kata Sandi

Dalam simulasi *phishing* korporat yang etis (*Ethical Phishing Campaign*), kata sandi atau data sensitif yang diisikan oleh pegawai pada formulir simulasi sama sekali tidak boleh disimpan di basis data.

b. Alasan Keamanan & Etika

- Perlindungan Privasi & Keamanan Pegawai: Jika sistem simulasi menyimpan data kata sandi asli secara *cleartext* atau terenkripsi sekalipun, basis data simulasi tersebut dapat menjadi target serangan baru (risiko kebocoran data sekunder).
- Tujuan Simulasi Adalah Edukasi, Bukan Pengawasan Intrusif: Fokus utama simulasi *phishing* adalah mengukur kesadaran psikologis pegawai (*behavioral metric*), bukan mengumpulkan kredensial pribadi pegawai.
- Kepatuhan Etis (Compliance): Mengumpulkan kredensial pegawai tanpa izin eksplisit melanggar regulasi privasi data dan prinsip *Ethical Hacking*. Sistem cukup mencatat *event* bahwa "pegawai melakukan submit data" tanpa mencatat isi teks kata sandinya.

2. Analisis Dashboard *Campaign Phishing* (/security/campaign-dashboard) (Soal 3b)

🕒 Aktivitas Event Kampanye Phishing Terbaru				Real-Time Telemetry
Waktu	Tipe Event	Alamat IP	User-Agent / Perangkat	Status Edukasi
23 Sep 2026, 13:39:38	Dilaporkan Karyawan	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	✓ Respon Teladan
23 Sep 2026, 13:39:35	Kunjungan (It-update)	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 13:33:43	Selesai Edukasi	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 13:13:54	Selesai Edukasi	127.0.0.1	Mozilla/5.0 (iPhone; CPU iPhone OS 18_7 like Mac OS X) App...	Netral
23 Sep 2026, 13:09:35	Selesai Edukasi	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 13:07:21	Kunjungan (It-update)	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 13:03:57	Selesai Edukasi	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 13:01:52	Dilaporkan Karyawan	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	✓ Respon Teladan
23 Sep 2026, 12:58:13	Selesai Edukasi	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	Netral
23 Sep 2026, 12:58:13	Kredensial Disubmit	127.0.0.1	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53...	⚠ Rentan (Butuh Training)

a. Analisis Metrik yang Tercatat

1. **Waktu (Timestamp):** Waktu presisi terjadinya interaksi pegawai dengan sistem.

2. **Tipe Event:** Jenis tindakan yang dilakukan oleh pengguna, meliputi:
 - Kunjungan (/it-update): Mengindikasikan bahwa pengguna telah membuka tautan phishing.
 - Kredensial Disubmit: Mengindikasikan pengguna terkecoh dan memasukkan data formulir.
 - Selesai Edukasi: Mengindikasikan pengguna telah menyelesaikan materi edukasi pada portal /awareness-education.
 - Dilaporkan Karyawan: Mengindikasikan pengguna menekan tombol "Laporkan Halaman Ini Sebagai Phishing / Mencurigakan".
3. **Alamat IP & User-Agent / Perangkat:** Detail teknis perangkat yang digunakan pengguna (misalnya Windows desktop atau iOS iPhone) untuk memvalidasi konteks akses.
4. **Status Edukasi:** Pengkategorian tingkat kerentanan pegawai, seperti:
 - **Respon Teladan:** Diberikan kepada pegawai yang melaporkan halaman *phishing* tanpa melakukan pengisian data.
 - **Rentan (Butuh Training):** Diberikan kepada pegawai yang terkecoh hingga melakukan tindakan *submit* kredensial.
 - **Netral:** Status awal saat mengunjungi atau saat menyelesaikan modul edukasi.

b. Penggunaan Data untuk Menilai Ketahanan Pegawai

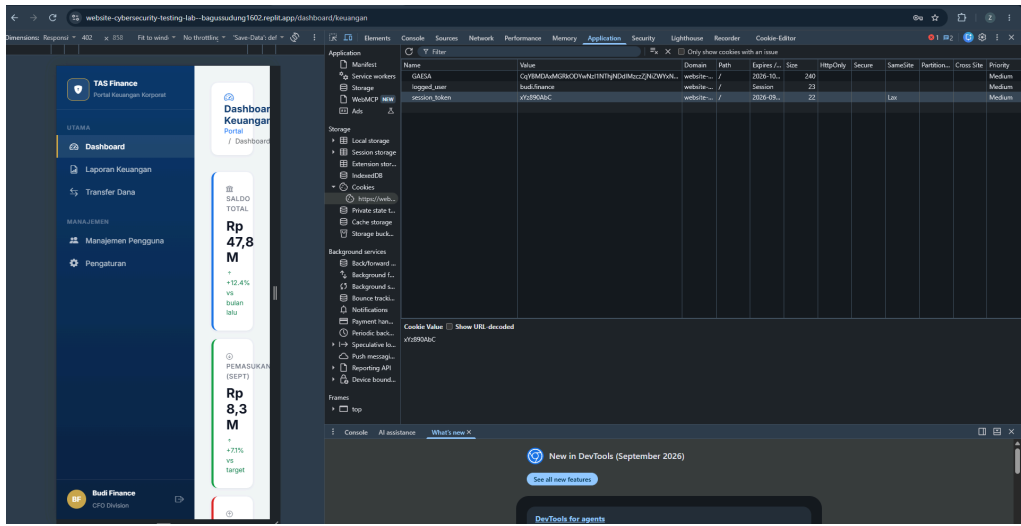
Data telemetry di atas digunakan oleh tim Keamanan Siber (*Information Security*) untuk:

- Mengukur Click Rate & Submit Rate: Menghitung persentase pegawai yang masih rentan terhadap serangan manipulasi psikologis.
- Mengukur Reporting Rate: Menilai efektivitas dan kecepatan pegawai dalam mengidentifikasi serta melaporkan ancaman keamanan ke tim SOC/IT Helpdesk.
- Intervensi Pelatihan Terarah (Targeted Training): Identifikasi kelompok atau individu dengan status "*Rentan (Butuh Training)*" agar dapat diberikan pelatihan kepekaan keamanan tambahan tanpa memberikan sanksi (*no-blame culture*).

2.2 Bagian 2: Pengujian Manajemen Sesi dan Kerentanan Session

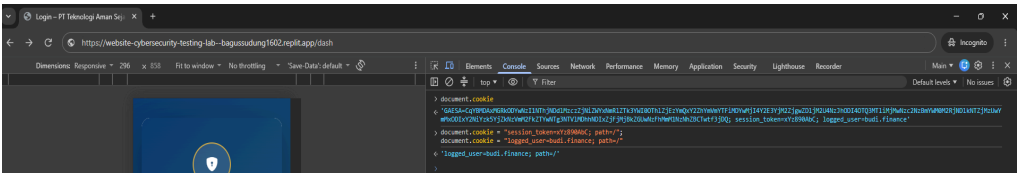
1. A.Ambil screenshot atribut cookie session_token. Catat nama, nilai token, serta status flag HttpOnly, Secure, dan SameSite

Atribut	Hasil Yang Ditemukan
Name	session_token
Value	xZ890AbC
HttpOnly	Tidak aktif / tidak dicentang
Secure	Tidak aktif / tidak dicentang
SameSite	Lax



B.Buka tab Console pada Developer Tools, jalankan perintah:

```
document.cookie
document.cookie = "session_token=xYz890AbC; path=/";
document.cookie = "logged_user=budi.finance; path=/"
```



Berdasarkan hasil pengamatan pada tabel Cookies di Developer Tools, cookie session_token memiliki nilai xZ890AbC. Flag HttpOnly dan Secure tidak diaktifkan, sedangkan atribut SameSite bernilai Lax.

Karena flag `HttpOnly` tidak diaktifkan, cookie tersebut dapat dibaca melalui JavaScript menggunakan `document.cookie`. Hal ini menunjukkan bahwa cookie sesi tidak memiliki perlindungan terhadap akses langsung dari skrip JavaScript di sisi klien.

C. Jelaskan mengapa nilai `session_token` dapat terbaca oleh perintah JavaScript tersebut. Kaitkan temuan ini dengan risiko pencurian sesi apabila web memiliki celah Cross-Site Scripting (XSS).

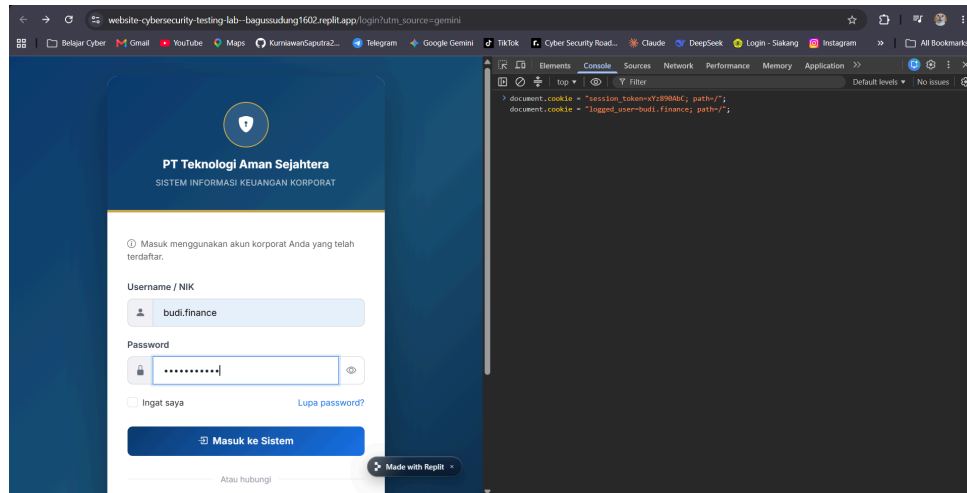
Nilai `session_token` dapat terbaca melalui perintah JavaScript `document.cookie` karena cookie tersebut tidak memiliki flag `HttpOnly` yang aktif. Flag `HttpOnly` berfungsi membatasi akses cookie melalui JavaScript di sisi klien. Berdasarkan hasil pengamatan pada Developer Tools, flag `HttpOnly` pada cookie `session_token` tidak diaktifkan sehingga JavaScript dapat membaca nilainya.

Kondisi ini menimbulkan risiko keamanan apabila website memiliki kerentanan Cross-Site Scripting (XSS). Penyerang dapat menyisipkan skrip JavaScript berbahaya ke dalam halaman website. Skrip tersebut berpotensi membaca nilai `session_token` dan mengirimkannya kepada penyerang. Jika token yang dicuri masih berlaku, penyerang dapat menggunakannya untuk mencoba mengambil alih sesi pengguna tanpa harus mengetahui kata sandi korban.

Untuk mengurangi risiko tersebut, pengembang disarankan mengaktifkan flag `HttpOnly` pada cookie sesi, menggunakan flag `Secure` agar cookie hanya dikirim melalui HTTPS, serta menerapkan validasi input dan output encoding untuk mencegah serangan XSS. Atribut `SameSite=Lax` juga membantu membatasi pengiriman cookie pada sebagian permintaan lintas situs, tetapi tidak dapat sepenuhnya mencegah XSS.

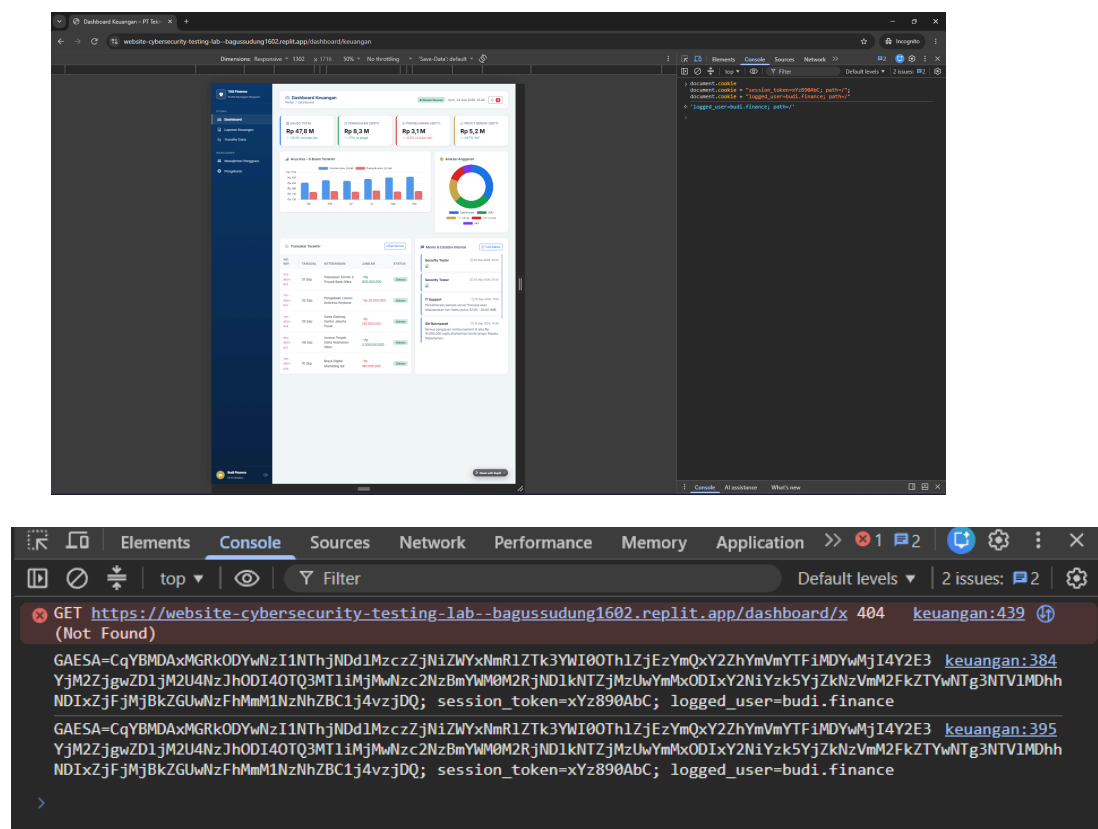
2. Lakukan pengujian pembajakan sesi (Session Hijacking)

A. Buka jendela peramban baru dalam mode Penyamaran (Incognito window)



B. Buka langsung tautan /dashboard/keuangan tanpa melakukan proses login.

Amati respons sistem (terjadi pengalihan ke /login)



Ketika URL `/dashboard/keuangan` diakses melalui jendela Incognito tanpa melakukan proses login, sistem mengalihkan pengguna ke halaman `/login`. Hal ini menunjukkan bahwa aplikasi menerapkan mekanisme autentikasi untuk

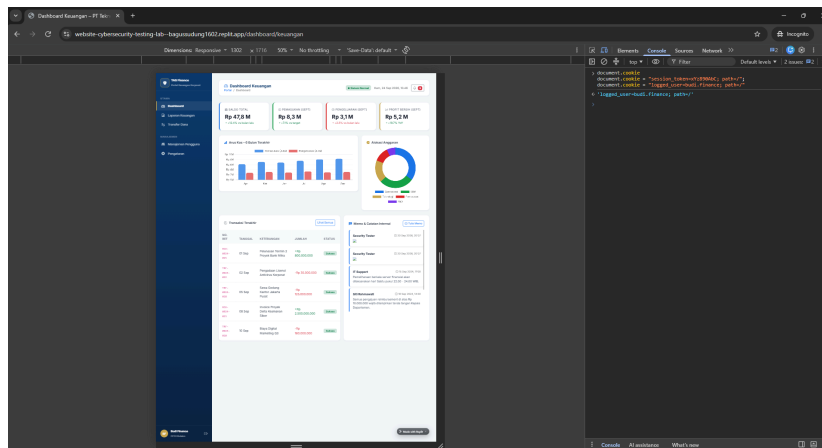
membatasi akses ke dashboard keuangan. Pengguna harus memiliki sesi yang valid agar dapat mengakses halaman tersebut.

C. Pada jendela penyamaran tersebut, buka Console (F12) dan suntikkan cookie sesi yang telah dicatat sebelumnya menggunakan perintah:

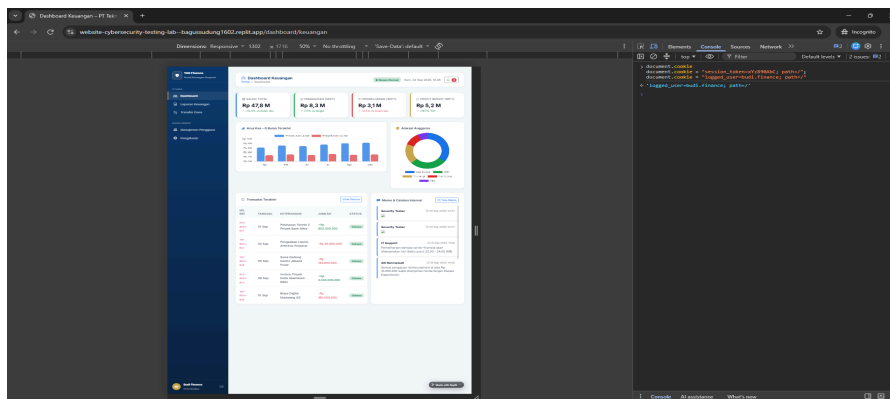
```
document.cookie
```

```
document.cookie = "session_token=xYz890AbC; path=/";
```

```
document.cookie = "logged_user=budi.finance; path=/"
```



D. Muat ulang (refresh) halaman. Jelaskan mengapa akun dapat langsung masuk ke dashboard finansial tanpa verifikasi kata sandi kembali.



Berdasarkan hasil pengujian pada jendela Incognito, setelah cookie sesi dimasukkan melalui Console dan halaman dimuat ulang (refresh), dashboard finansial berhasil diakses tanpa perlu memasukkan kata sandi kembali.

Hal ini terjadi karena aplikasi menggunakan mekanisme autentikasi berbasis sesi. Cookie `session_token` berfungsi sebagai identitas sesi pengguna yang telah terautentikasi. Ketika halaman dimuat ulang, browser mengirimkan cookie tersebut ke server. Jika token diterima sebagai token sesi yang valid dan masih

aktif, server mengizinkan akses ke dashboard tanpa meminta verifikasi kata sandi kembali.

Pengujian ini menunjukkan bahwa seseorang yang memperoleh token sesi yang valid berpotensi mengakses akun pengguna tanpa mengetahui kata sandinya. Kondisi tersebut merupakan risiko Session Hijacking, terutama jika token dapat dicuri melalui kerentanan seperti Cross-Site Scripting (XSS).

3. Uji Coba Mitigasi Flag HttpOnly:

A. Buka halaman audit keamanan pada tautan: /security/session-audit

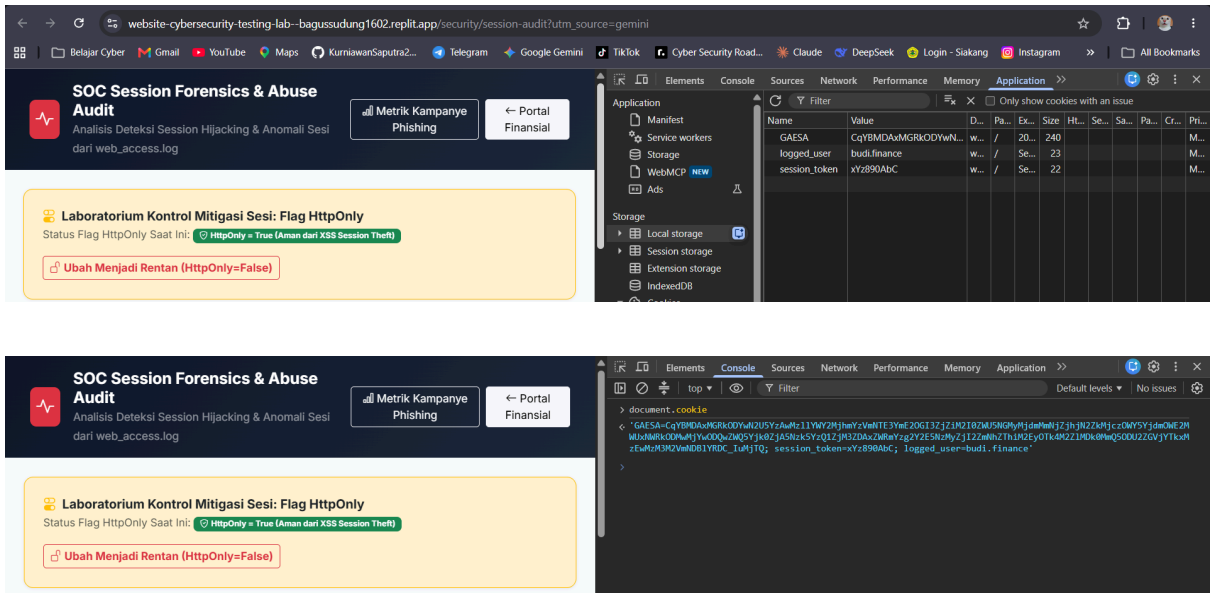
B. Klik tombol "Terapkan Mitigasi (HttpOnly=True)".

The screenshot shows the 'Laboratorium Kontrol Mitigasi Sesi: Flag HttpOnly' section. The status is 'HttpOnly = True (Aman dari XSS Session Theft)'. A button 'Ubah Menjadi Rentan (HttpOnly=False)' is visible. The dashboard displays 6837 total log accesses, 2 session tokens, and 2 indicators of session abuse. An alert indicates a high risk of session hijacking with a list of detected user agents.

The screenshot shows the same dashboard after the mitigation is applied. The status is now 'HttpOnly = False (Rentan Pembajakan via document.cookie)'. A button 'Terapkan Mitigasi (HttpOnly=True)' is visible. The total log accesses have increased to 6835, and the session tokens remain at 2. The alert section remains the same, indicating a high risk of session hijacking.

Setelah mitigasi diterapkan, cookie session_token dikonfigurasi dengan flag HttpOnly=True. Dampaknya, peramban memblokir akses JavaScript terhadap cookie tersebut, sehingga perintah document.cookie tidak lagi dapat membaca nilai token sesi. Hal ini secara efektif melindungi sesi pengguna dari potensi pencurian token melalui serangan Cross-Site Scripting (XSS).

C.Lakukan proses login ulang, lalu coba kembali jalankan perintah document.cookie pada Console. Jelaskan perbedaan hasilnya dan bagaimana flag HttpOnly melindungi sesi pengguna.



Setelah melakukan login ulang, kemudian menjalankan perintah document.cookie pada Console, terdapat perbedaan hasil antara sebelum dan sesudah penerapan flag HttpOnly. Pada kondisi sebelumnya, ketika cookie sesi belum menggunakan HttpOnly, perintah document.cookie dapat menampilkan cookie yang digunakan oleh sesi pengguna. Hal ini menunjukkan bahwa cookie tersebut dapat diakses melalui JavaScript yang berjalan pada halaman. Setelah login ulang dengan flag HttpOnly aktif, hasil document.cookie tidak lagi menampilkan cookie sesi yang dilindungi HttpOnly. Meskipun cookie tersebut tetap tersimpan di browser dan tetap digunakan dalam proses komunikasi dengan server, JavaScript pada halaman tidak dapat membacanya.

Perbedaan Hasil

Kondisi	Hasil document.cookie	Akses JavaScript
HttpOnly = False	Cookie sesi dapat terlihat	Dapat diakses
HttpOnly = True	Cookie sesi HttpOnly tidak terlihat	Tidak dapat diakses

Bagaimana HttpOnly melindungi sesi?

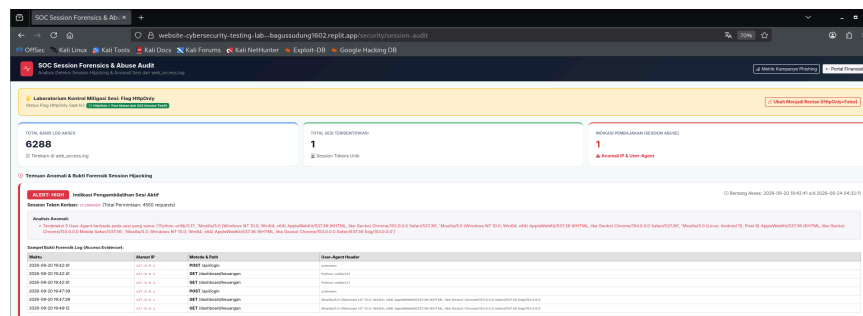
Flag HttpOnly memberikan pembatasan agar cookie tidak dapat diakses melalui JavaScript menggunakan document.cookie. Dengan demikian, apabila terdapat serangan Cross-Site Scripting (XSS) yang berhasil menjalankan JavaScript pada halaman, script tersebut tidak dapat membaca secara langsung cookie sesi yang memiliki flag HttpOnly. Cookie tersebut tetap dikirim secara otomatis oleh browser kepada server sesuai aturan cookie, sehingga mekanisme login tetap dapat berjalan. Jadi, HttpOnly tidak membuat cookie hilang, tetapi membatasi akses cookie dari sisi JavaScript

2.3 Bagian 3: Analisis Log Server dan Deteksi Penyalahgunaan Sesi

1. Buka halaman pemantauan sesi pada tautan:

<https://website-cybersecurity-testing-lab--bagussudung1602.replit.app/security/session-audit>

2. Format catatan akses pada log server memiliki susunan sebagai berikut:



The screenshot shows a web application interface for session forensics. It includes a header with navigation links, a main content area with summary statistics, and a table of session logs. The table has columns for 'Index', 'Access ID', 'Access Date', 'Access Method', and 'User Agent/Device'. The data shows multiple access attempts from different IP addresses and user agents, with some marked as 'Anomali' (Anomaly).

Index	Access ID	Access Date	Access Method	User Agent/Device
1	1	2024-09-25 10:42:41	GET	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
2	2	2024-09-25 10:42:41	GET	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
3	3	2024-09-25 10:42:41	GET	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
4	4	2024-09-25 10:42:41	GET	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0
5	5	2024-09-25 10:42:41	GET	Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/109.0

3. Lakukan analisis terhadap data temuan pada halaman audit tersebut, kemudian jawab butir pertanyaan berikut:

A. Jelaskan indikasi Anomali alamat IP (IP address shift) yang terdeteksi pada suatu session_token aktif. Mengapa satu token yang digunakan bersamaan oleh dua alamat IP berbeda merupakan indikasi kuat terjadinya session hijacking?

Jawab : Anomali IP Address Shift terjadi ketika satu session_token aktif digunakan dari dua alamat IP yang berbeda dalam waktu yang berdekatan. Hal ini mencurigakan karena sebuah session biasanya digunakan oleh pengguna yang sama dengan pola akses yang relatif konsisten. Satu token yang digunakan

C. Lampirkan tangkapan layar bukti rekaman log (evidence) yang menunjukkan adanya perbedaan IP atau User-Agent tersebut.

Sampel Bukti Forensik Log (Access Evidence)

Waktu	Alamat IP	Metode & Path	User-Agent Header
2020-10-20 10:42:41	127.0.0.1	POST /api/login	python
2020-10-20 10:42:41	127.0.0.1	GET /admin/keuangan	Python-urllib/3.11
2020-10-20 10:42:41	127.0.0.1	GET /admin/keuangan	Python-urllib/3.11
2020-10-20 10:47:09	127.0.0.1	POST /api/login	python
2020-10-20 10:47:09	127.0.0.1	GET /admin/keuangan	Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.0.0 Safari/537.36 Edg/80.0.0.0)
2020-10-20 10:48:12	127.0.0.1	GET /admin/keuangan	Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.0.0 Safari/537.36 Edg/80.0.0.0)

Tangkapan layar bukti rekaman log terlampir di atas. Pada bagian “Sampel Bukti Forensik Log (Access Evidence)” terlihat bahwa:

- Alamat IP: 127.0.0.1 digunakan pada seluruh request yang ditampilkan, sehingga pada bukti ini tidak terlihat adanya perbedaan IP.
- User-Agent: terdapat perbedaan User-Agent pada aktivitas session yang diaudit.
- Python-urllib/3.11
- Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/80.0.0.0 Safari/537.36 Edg/80.0.0.0

Perbedaan User-Agent tersebut menunjukkan adanya akses dari client/perangkat dengan karakteristik berbeda, sehingga menjadi salah satu bukti anomali pada session yang sedang diaudit.

BAB III

REKOMENDASI TEKNIS DAN KEBIJAKAN KEAMANAN

3.1 Bagian 4 : Rancangan Rekomendasi dan Kebijakan Keamanan

1. Aspek Teknis Aplikasi

- A. Rekomendasi penerapan konfigurasi cookie sesi yang aman (HttpOnly, Secure, SameSite=Strict).

Jawaban :

- HttpOnly=True: Mencegah akses terhadap cookie (seperti session_token) melalui skrip sisi klien (JavaScript), sehingga menutup celah pencurian sesi apabila aplikasi mengalami kerentanan Cross-Site Scripting (XSS).
- Secure=True: Memastikan bahwa cookie sesi hanya dikirimkan melalui jalur komunikasi terenkripsi (HTTPS), melindungi token dari penyadapan di jaringan publik (packet sniffing).
- SameSite=Strict (atau Lax): Mencegah pengiriman cookie pada permintaan lintas situs (cross-site requests), guna memitigasi risiko serangan Cross-Site Request Forgery (CSRF).

- B. Rekomendasi mekanisme Session Invalidation dan Session Regeneration saat proses login untuk mencegah serangan Session Fixation.

Jawaban :

- Pencegahan Session Fixation: Mengimplementasikan regenerasi ID sesi secara otomatis setiap kali pengguna berhasil melakukan proses autentikasi (proses login). ID sesi lama yang kosong harus dimusnahkan dan diganti dengan token sesi baru yang unik.
- Session Invalidation yang Aman: Memastikan bahwa saat pengguna menekan tombol logout atau ketika sesi kedaluwarsa, server secara aktif menghapus token dari sisi basis data/penyimpanan server dan menginstruksikan peramban untuk menghapus cookie terkait.

- C. Rekomendasi mekanisme Session Binding (mengikat token sesi dengan sidik jari IP atau perangkat pengguna).

Jawaban :

- Mengikat token sesi dengan parameter unik pengguna yang sah, seperti sebagian dari alamat IP atau fingerprint peramban (User-Agent).
- Jika server mendeteksi adanya perubahan alamat IP secara drastis atau ketidakcocokan User-Agent di tengah sesi yang aktif, sistem harus secara otomatis membekukan sesi tersebut dan meminta pengguna untuk melakukan verifikasi ulang guna mencegah eksploitasi session hijacking.

2. Aspek Tata Kelola dan SDM:

A. Prosedur standar operasional (SOP) bagi pegawai ketika menerima komunikasi mencurigakan yang mengatasnamakan bagian TI internal.

Jawaban :

- Verifikasi Kanal Resmi: Pegawai dilarang keras mengklik tautan pembaruan data, reset password, atau memasukkan kredensial melalui tautan yang dikirimkan melalui email internal/eksternal yang mencurigakan, meskipun mengatasnamakan Departemen TI internal.
- Jalur Eskalasi Resmi: Menyediakan kanal pelaporan khusus (misalnya tombol phishing report atau kontak internal terpusat) bagi pegawai untuk memvalidasi keabsahan pengumuman darurat langsung ke bagian Helpdesk atau SOC perusahaan.

B. Kebijakan pelaksanaan simulasi phishing berkala dan evaluasi kesadaran keamanan tanpa sistem hukuman (no-blame culture).

Jawaban :

- Pelatihan Rutin: Menyelenggarakan simulasi uji coba phishing secara berkala (tanpa pemberitahuan sebelumnya) untuk mengukur tingkat kewaspadaan pegawai secara kontinu.
- Budaya Tanpa Hukuman (No-Blame Culture): Mengubah pendekatan penanganan kesalahan pegawai dari sistem hukuman (punishment) menjadi pendekatan edukatif. Pegawai yang terjebak dalam simulasi tidak diberikan sanksi, melainkan diarahkan mengikuti modul pelatihan penyadaran keamanan (awareness education) agar termotivasi untuk belajar dari kesalahan tanpa rasa takut melaporkan insiden.

BAB IV

KESIMPULAN

Evaluasi praktikal keamanan siber oleh Kelompok 8 pada portal finansial PT Teknologi Aman Sejahtera menyoroti kerentanan pada *human layer* dan *technical layer*. Dari sisi *human layer*, simulasi *phishing* membuktikan bahwa teknik manipulasi psikologis berbasis urgensi serta ancaman penghapusan akun efektif mengecoh pegawai, yang ditandai dengan adanya *red flags* seperti penggunaan domain logo asing, *countdown timer*, dan *typosquatting*. Melalui dasbor kampanye, interaksi pegawai dipantau dan diarahkan ke portal edukasi guna menerapkan *no-blame culture* bagi individu yang rentan. Sementara itu, dari sisi teknis, pengujian mendapati bahwa cookie sesi awal tidak mengaktifkan atribut `HttpOnly` dan `Secure`, sehingga rentan dibaca oleh skrip sisi klien melalui celah XSS dan memungkinkan terjadinya *Session Hijacking* untuk mengambil alih akun tanpa kata sandi.

Sebagai solusi atas temuan tersebut, laporan merekomendasikan mitigasi teknis dan tata kelola yang ketat untuk mencegah eksploitasi lanjutan. Secara teknis, penerapan `HttpOnly=True` terbukti sukses memblokir akses JavaScript terhadap token sesi, sehingga pencurian token dapat dicegah. Namun, analisis forensik log server juga mendeteksi adanya *User-Agent mismatch*, di mana token yang sama dapat disalahgunakan melalui alat otomatisasi seperti `cURL` atau `Python-urllib`. Oleh karena itu, perusahaan disarankan untuk menerapkan konfigurasi cookie yang aman (`HttpOnly`, `Secure`, `SameSite=Strict`), *Session Regeneration*, dan *Session Binding*, serta memperkuat aspek SDM melalui peningkatan SOP verifikasi kanal internal dan pelatihan *security awareness* berkala.